

Ameaças, Vulnerabilidades e Risco

Vulnerabilidades e risco

Segundo ISO 27002, “Vulnerabilidade é uma fragilidade de um ativo (ou grupo de ativos) que pode ser explorada por uma ou mais ameaças.”

- Ausência de controle de acesso
- Senhas Fracas
- Sistemas Op. Desatualizados
- Falta de Antivírus
- Bugs de software
- Recursos Humanos despreparados (Falta de treinamento)
- Ausência de rotinas de backup

Destaque:

Tipos de vulnerabilidades:

- Vulnerabilidades de processos;
- Vulnerabilidades tecnológicas; e
- Vulnerabilidades das pessoas.

QUESTÃO DE CONCURSO

1- (Fundação CEFETMINAS - IFAM - Professor - Área: Informática - 2022) O risco à segurança da informação está associado ao potencial de ameaças explorarem vulnerabilidades de um ativo e, desse modo, causarem danos a uma organização. Avalie as afirmações sobre ativos.

I - Podem incluir informações na forma de documentos, base de dados, contratos, documentação de sistemas, procedimentos, manuais, logs de sistemas, planos e guias.

II - Podem incluir programas de computador, tais como programas do sistema, programas do usuário e programas de desenvolvimento.

III - Podem incluir mídias como CD-ROMs, pen drives, HDs externos etc...

IV- Podem incluir pessoas, habilidades, experiência e coisas intangíveis.

Está correto apenas o que se afirma em:

A) II.

B) II e III.

C) I e IV.

D) I, II e III.

E) I, II, III e IV.

2- (CESPE/CEBRASPE - BANRISUL - Técnico em Tecnologia da Informação - Área: Quality Assurance e Analistas de Teste - 2022) Vulnerabilidade é o grau de suscetibilidade de um objeto a uma ameaça.

Na ISO 31000, **risco** é definido como sendo o “efeito da incerteza nos objetivos”.

“Probabilidade de uma ameaça explorar uma vulnerabilidade.”

Nível de Risco é a
 “magnitude de um risco,
 expressa em termos da
 combinação das
 consequências (impacto)
 pelas suas probabilidades”

Probabilidade			RISCO	
			1 a 3	Baixo
			4 a 5	Médio
			6 a 9	Alto
Probabilidade	Baixo	Médio	Alto	
	Baixo	Médio	Alto	
	Baixo	Médio	Alto	
Baixo	1	2	3	
Médio	2	4 - 5	6	
Alto	3	6	9	
	Baixo	Médio	Alto	IMPACTO

Dependendo do risco pode-se tomar as seguintes ações em relação a ele:

Evitar - Visa evitar completamente que este risco ocorra, através de ações para levar a probabilidade do risco a zero, por exemplo, desligando um servidor vulnerável.

Transferir - Transfere para terceiros o ônus do risco, por exemplo, fazendo um seguro, ou através de cláusulas contratuais, a transferência não elimina nem diminui o risco.

Mitigar - Visa reduzir a probabilidade da ocorrência ou o impacto de um risco a um nível aceitável. Exemplo: Tomar medidas de segurança ou prever sistemas ou recursos redundantes.

Aceitar - Significa aceitar os riscos sem tomar nenhuma providência ou estabelecer um plano de contingência caso o risco ocorra. Isso normalmente é feito quando a probabilidade de ocorrência e o impacto são baixos ou quando o custo de mitigar ou transferir o risco é muito maior que o valor do ativo. Por exemplo, não fazer seguro de um carro de muito baixo valor.

QUESTÃO DE CONCURSO

1- (IFMT - IFMT - Técnico de Laboratório - Área: Informática - 2023) As sentenças abaixo são inspiradas no texto de Ramos (2006) sobre Segurança da Informação:

- I. Evento que tem potencial em si próprio para comprometer os objetivos da organização e pode trazer danos diretos aos ativos, ou prejuízos decorrentes de situações inesperadas.
- II. Ausência de um mecanismo de proteção ou falhas em um mecanismo de proteção existentes.
- III. Medida indicativa de probabilidade de uma ocorrência que possa comprometer os objetivos da organização, combinada com os impactos que ela trará.

Fonte: (RAMOS, Anderson. Security Officer - 1: guia oficial para formação de gestores em segurança da informação. Porto Alegre: Zouk, 2006.)

Tais sentenças descrevem, respectivamente, as definições de:

- A) Ameaça, Vulnerabilidade e Risco.
- B) Vulnerabilidade, Ameaça e Impacto.
- C) Ameaça, Risco e Prejuízo.
- D) Impacto, Ameaça e Prejuízo.
- E) Risco, Vulnerabilidade e Impacto.